Incident Report: Simulated Adversay Compromise

Report ID: IR-2024-001 **Date of Report:** 10/30/2026 **Analyst:** Karim Shawky **Classification:** Lab/Training - Non-Production Environment **Status:** Closed

---

1. Summary

On October 27, 2026 at 5:21:58 PM, a simulated adversary (red team operator on Kali Linux) gained initial access to a Windows 11 workstation (SOC-WIN11-SPLUNK-01) via a malicious executable delivered over HTTP and executed by the user. The attacker established a persistent command-and-control (C2) channel using the sliver C2 framework, performed local enumeration, and successfully dumped credential material - including NTLM hashes and a plaintext auto-logon password - from the target host. A critical misconfiguration was identified: the Windows auto-logon password was stored in plaintext in LSA Secrets (MITRE ID: T1552.004), and both the Administrator and vboxuser accounts shared identical NTLM hashes.

For scope reasons, lateral movement and persistence phases were not executed in this exercise. One detection gap was identified and closed with custom Splunk SPL Queries.

---

2. Scope and Affected Systems

Host	OS	Role	IP Address
SOC-WIN11-SPLUNK-01	Windows 11 (64-Bit)	Target Workstation	192.168.56.20/24
SOC-KALI-01	Kali Linux	Attack Workstation	192.168.56.50/24
SOC-SPLUNK-01	Ubuntu 26.04 LTS	Splunk Server	192.168.56.10/24

---

3. Attack Timeline

Timestamp (UTC)	Phase	Technique	MITRE ID	Detected?
2026-10-27 22:51:31.300	Initial Access	Ingress Tool Transfer	T1105	YES
2026-10-27 22:51:56.184	Initial Access	User Execution	T1204.002	YES
2026-10-27 22:51:57.635	C2	Application Layer Protocol: Web	T1071.001	YES
2026-10-27 22:53:08.841	Discover	System Info. Discovery	T1082	YES
2026-10-27 22:53:36.969	Discover	Account Discover	T1087	YES
2026-10-27 23:02:08.765	Credential Access	Tool Transfer	T1003.002	YES
2026-10-27 23:02:08.765	Credential Access	SAM Dump + Credentials in Registry	T1552.004	NO (Detection Gap)

---

4. Technical Analysis

4.1 Initial Access (T1204.002, T1105)

** What Happened: ** The adversary hosted a malicious PE file (`update_helper.exe`, SHA256: 696ae695ee20382522dfa00504cdd025ccff22030e019df986461d8c313ffc45) on an attacker-controlled HTTP server and used Powershell's `Invoke-WebRequest` cmdlet to download it to `C:\Users\Public\`. The file was then executed via `Start-Process`, establishing an outbound HTTPS beacon the the adversary infrastructure at 192.168.56.50:443 using the Sliver C2 framework.

** Evidence: ** Sysmon Event ID 1 captured the process creation of `update_helper.exe`. Sysmon Event ID 11 captured the file write to `C:\Users\Public\`. Sysmon Event ID 3 captured the outbound network connection to 192.168.56.50:443

[SCREENSHOT: Initial Access] [SCREENSHOT: C2 Beacon]

4.2 Discovery (T1082, T1087)

** What Happened: ** The adversary executed a series of native Windows discovery commands via an interactive shell: `whoami /all`, `systeminfo`, `net user`, `netlocalgroup administrators`, `tasklist /v`, `netstat -ano`

** Evidence: ** Sysmon Event ID 1 logged each process creation with full command-line arguments visible.

[SREENSHOT: Discovery]

4.3 Credential Access (T1003.002, T1552.004)

** What Happened: ** The adversary uploaded and executed Mimikatz `mimikatz.exe` from `C:\Windows\Temp\`. Running non-interactively with `token::elevate`, they used `lsadump::sam` to dump NTLM hashes for all local accounts, and `lsadump::secrets` to extract LSA secrets.

** Critical Findings: ** `lsadump::secrets` revealed a plaintext `DefaultPassword` value in LSA Secrets, indicating the system is configured for automatic logon with the credential stored in cleartext (T1552.004). This yielded a usable plaintext password without any brute-force or cracking.

** Additional finding: ** The Administrator account and the vboxuser account share identical NTLM hashes (`d0d6430a1503be8ccfd023e6481b7a2a`), indicating both accounts use the same password - a significant miscofiguration.

** Evidence: ** Sysmon Event ID 1 captured `mimikatz.exe` process creation. The `token::elevate` technique generates a process token impersonation event. [SCREENSHOT: MIMIKATZ EXECUTION AND FILE DROP]

---

5. Recommended Containment Actions

Priority	Action	Rationale
IMMEDIATE	Isolate SOC-WIN11-01 from the network	Prevent active C2 communication
IMMEDIATE	Terminate process `update_helper.exe`	Kill active C2 session
IMMEDIATE	Block 192.168.56.50:443 at the perimeter	Block C2 callback
IMMEDIATE	Reset Administrator and vboxuser passwords	Invalidate captured NTLM hashes
SHORT-TERM	Disable auto-logon and remove DefaultPassword from LSA Secrets	Eliminate plaintext credential exposure
SHORT-TERM	Remove malicious files from disk (`update_helper.exe`, `mimikatz.exe`)	Reduce dwell time risk

6. Indicators of Compromise (IoCs)

Files

Filename	Path	SHA256	MD5
update_helper.exe	C:\Users\Public\	696ae695ee20382522dfa00504cdd025ccff22030e019df986461d8c313ffc45	75cb12221fd29
mimikatz.exe	C:\Windows\Temp\	94795fd89366e01bd6ce6471ff27c3782e2e16377a848426cf0b2e6baee9449b	d3b17ddf0b98fc

Network

Indicator	Type	Description
192.168.56.50	IPv4	C2 server (Sliver HTTPS listener)
192.168.56.50:443	IP:Port	Sliver beacon callback

Credentials

Account	Type	Value	Source
Administrator	NTLM hash	856209c130b5ef357d27d7c61af4ec32	lsadump::sam
vboxuser	NTLM hash	856209c130b5ef357d27d7c61af4ec32	lsadump::sam
vboxuser	Plaintext	.....	LSA Secrets (DefaultPassword)

---

7. MITRE ATTACK Mapping

Tactic	Technique	ID	Tool	Status
Initial Access	User Execution: Malicious File	T1204.002	Sliver implant	Executed + Detected
Command and Control	Application Layer Protocol: Web	T1071.001	Sliver HTTPS	Executed + Detected
Discovery	System Information Discovery	T1082	systeminfo.exe	Executed + Detected
Discovery	Account Discovery	T1087	net.exe	Executed + Detected
Credential Access	OS Credential Dumping: SAM	T1003.002	Mimikatz	Executed + Detected
Credential Access	Credentials in Registry	T1552.004	Mimikatz lsadump::secrets	Executed, gap closed
Credential Access	OS Credential Dumping: LSASS	T1003.001	Blocked by PPL	Blocked — not executed

8. Remediation Recommendations

1. **Disable auto-logon** and remove the `DefaultPassword` value from HKLM\SECURITY\Policy\Secrets`. No system should store plaintext credentials in LSA Secrets for normal operation.
2. **Enforce unique passwords** across all local accounts. The Administrator and vboxuser accounts sharing an identical NTLM hash means compromising one instantly compromises the other.
3. **Maintain LSASS PPL enforcement** - the UEFI-level protection (RunAsPPL = 0x2) successfully blocked direct LSASS memory access. Do not downgrade this setting.
4. **Implement application allowlisting** (Windows Defender Application Control or AppLocker) to prevent unsigned binaries from executing from user-writable paths like `C:\Users\Public`.
5. **Alert on new processes from user-writable paths** - any executable launching from `C:\Users\Public\`, `C:\Temp\`, or `%APPDATA%\` should trigger a medium-severity alert.

9. Lessions Learned

- **LSASS PPL at UEFI level (0x2) is highly effective.** It blocked `sekurlsa::logonpasswords` completely. Enforce RunAsPPL at the UEFI level on all workstations, not just via the registry (which can be reversed).
- **LSA Secrets is a high-value target often overlooked.** `lsadump::secrets` recovered a plaintext password without touching LSASS Detection coverage for LSA secret access was missing by default.
- **Shared NTLM hashes compound credential theft.** A single credential dump compromised two accounts simultaneously. Password uniqueness is a detection and containment control, not just a security hygiene measure